



Lucerne University of
Applied Sciences and Arts

**HOCHSCHULE
LUZERN**

Informatik

FH Zentralschweiz

Datensicherheitsvorfall

- Ursula Uttinger
- Rotkreuz, 25. November 2025

Lernziele

Die Studierenden

- Wissen, was ein „Datensicherheitsvorfall“ ist
- Können gemäss den gesetzlichen Vorgaben agieren
- Die Kommunikation ist adressatengerecht

Die drei häufigsten Angriffe

Phishing



Ransomware



DDoS / Websites

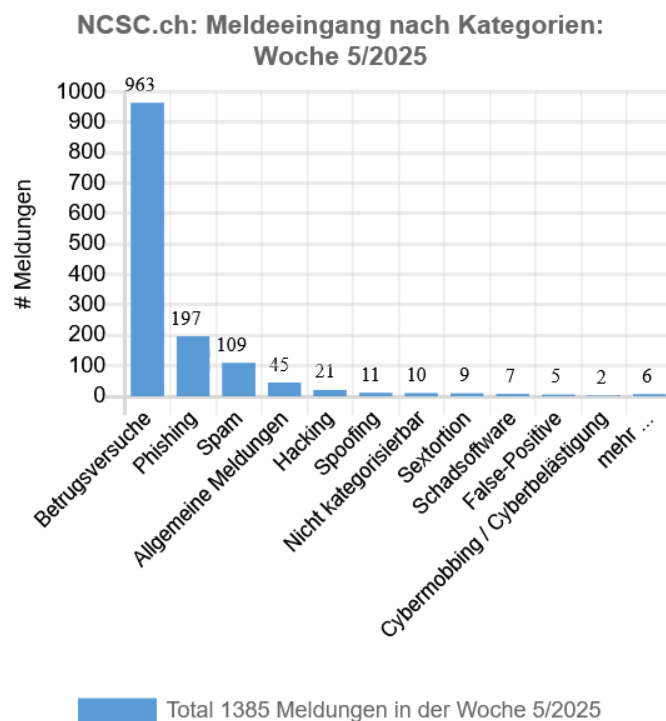


Und KI?

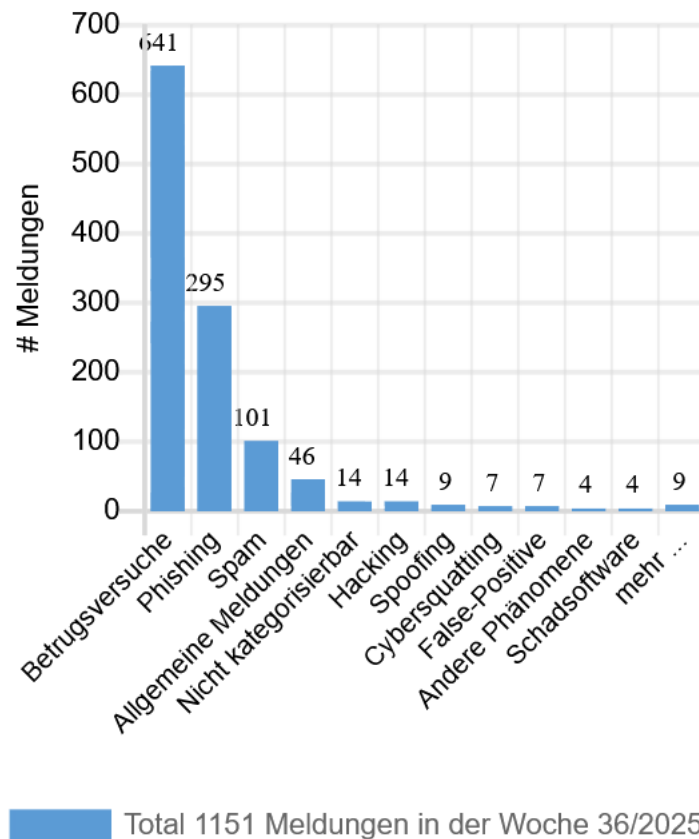
- Deepfake
- [Einfluss von KI auf die Cyberbedrohung](#)

Mit dem gezielten Einsatz von KI nehmen betrügerische E-Mails, SMS und Anrufe dramatisch zu. Der Grossteil dieser Vorfälle entfällt auf Spear-Phishing-Angriffe – oft das initiale Einfallstor für Ransomware-Attacken. Da Organisationen ihre Systeme verstärkt patchen und absichern, setzen Cyberkriminelle auf KI-gestützte Angriffstechniken. Mit perfider Präzision richten sie maximalen Schaden an und erpressen hohe Lösegeldsummen.

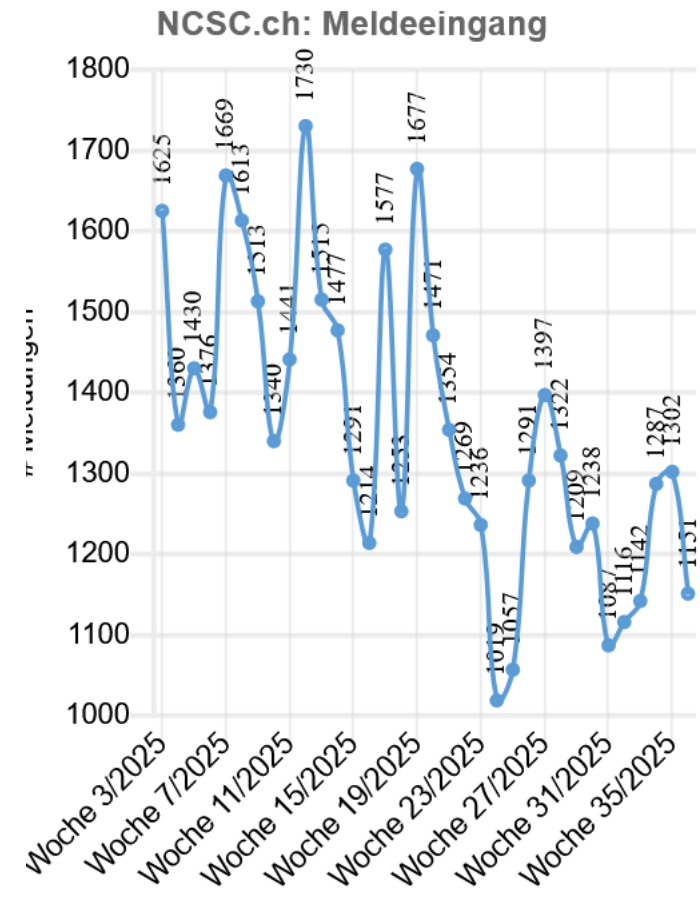
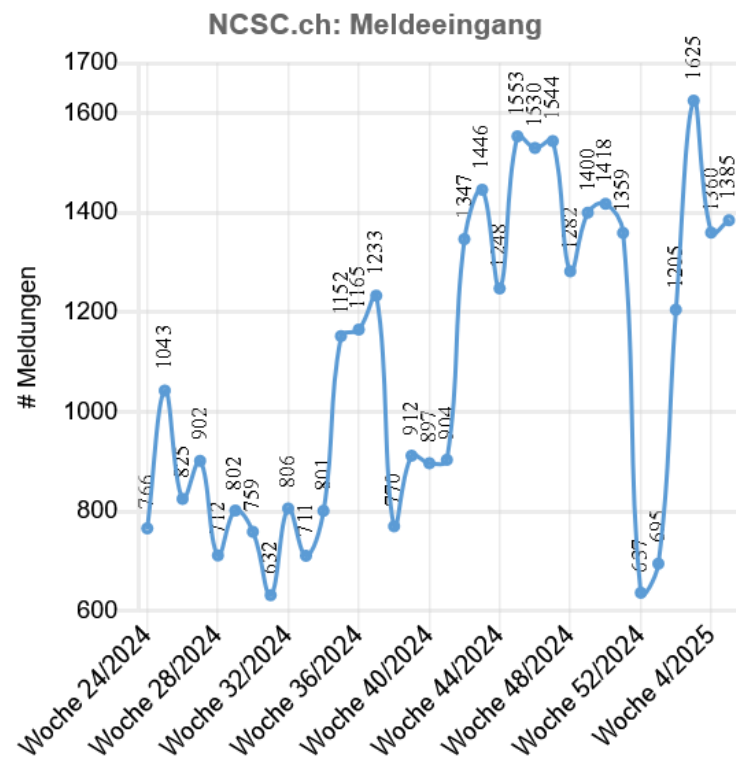
Meldungen beim NCSC



**NCSC.ch: Meldeeingang nach Kategorien:
Woche 36/2025**



Meldungen beim NCSC



Security Reports - BACS

- [BACS](#) – Studieren Sie die Seite
- ACHTEN AUF SECURITY-REPORTS
- In vielen Fällen haben Organisationen Benachrichtigungen von externen Personen ignoriert oder schlecht auf relevante Informationen über einen Verstoß reagiert → oft hätte die Veröffentlichung der Daten (data-breach) so noch verhindert werden können.
- Security-Reports sowohl von Insidern als auch von Outsidern müssen mit Dringlichkeit durch kompetente Leute behandelt werden
- Jeder Außenstehenden leicht, kritische Security-Informationen zu melden, und haben Sie eine klare und öffentlich bekannte (Web-Seite) Richtlinie, wo Security-Reports gemeldet werden können

Eigene Version veröffentlichen

Informations-Hoheit erlangen → primären Informationsquelle sein

ÖFFENTLICHE OFFENLEGUNG & KOMMUNIKATION

Eigene Version des Vorfalls frühzeitig und ehrlich auf einem formellen Kanal veröffentlichen.

Primären Referenz für Benutzer und die Medien.

Bei einem Verstoß suchen betroffene Benutzer und die Öffentlichkeit nach weiteren Informationen und beginnen spekulieren.

- Irreführende Aussagen vermeiden und Botschaft einfach, ehrlich und prägnant halten.
- Bei Bedarf wichtige Details angeben (für die Risikobewertung der Benutzer) und die Verantwortung für das Problem übernehmen.
- Bereitschaft zeigen, die Dinge richtig zu machen, und die Entschlossenheit, künftigen Schwierigkeiten vorzubeugen.

Wie ist der Schutz gehackter Daten?

- Strafgesetzbuch
- Datenschutzgesetz
- Spezialgesetze – u.a. Bankengesetz
- Datenhehlerei?
- [Vgl. Artikel](#)

ISG – weitere Meldepflicht

- Ziel: Schutz der Schweiz vor Cyberbedrohung => Meldepflichten
- Bestimmte Stellen haben eine Meldepflicht – vgl. [Art. 74b ISG](#)
- Beim Verstoss – neu Bussen (seit Oktober 2025)
- Vgl. auch: [BACS Meldepflicht](#)

Gesetzliche Grundlage

- Art. 24 DSG: Meldung von Verletzung der Datensicherheit
- [EDÖB](#)

Art. 24 DSGVO

- ¹ Der Verantwortliche meldet dem EDÖB **so rasch als möglich** eine **Verletzung der Datensicherheit**, die **voraussichtlich** zu **einem hohen Risiko für die Persönlichkeit** oder die **Grundrechte** der betroffenen Person führt.
- ² **In der Meldung** nennt er mindestens die **Art der Verletzung** der Datensicherheit, deren **Folgen** und die **ergriffenen oder vorgesehenen Massnahmen**.
- ³ Der **Auftragsbearbeiter** meldet dem Verantwortlichen so rasch als möglich eine Verletzung der Datensicherheit.
- ⁴ Der Verantwortliche **informiert die betroffene Person**, wenn es zu ihrem **Schutz erforderlich** ist oder der **EDÖB** es **verlangt**.

Art. 24 DSGVO

⁵ Er kann die Information an die betroffene Person **einschränken, aufschieben oder darauf verzichten**, wenn:

- a. ein Grund nach **Artikel 26 Absatz 1 Buchstabe b oder Absatz 2 Buchstabe b** vorliegt oder eine gesetzliche Geheimhaltungspflicht dies verbietet;
- b. die Information unmöglich ist oder einen **unverhältnismässigen Aufwand** erfordert; oder
- c. die Information der betroffenen Person durch eine **öffentliche Bekanntmachung** in vergleichbarer Weise sichergestellt ist.

⁶ Eine Meldung, die aufgrund dieses Artikels erfolgt, darf in einem **Strafverfahren gegen die meldepflichtige Person** nur mit deren Einverständnis verwendet werden.

Art. 26

¹ Der Verantwortliche kann die Auskunft verweigern, einschränken oder aufschieben, wenn:

b. dies aufgrund überwiegender Interessen Dritter erforderlich ist

b. Der Verantwortliche ist ein Bundesorgan, und eine der folgenden Voraussetzungen ist erfüllt:

1. Die Massnahme ist wegen überwiegender öffentlicher Interessen, insbesondere der inneren oder der äusseren Sicherheit der Schweiz, erforderlich.
2. Die Mitteilung der Information kann eine Ermittlung, eine Untersuchung oder ein behördliches oder gerichtliches Verfahren gefährden.

Was ist was?

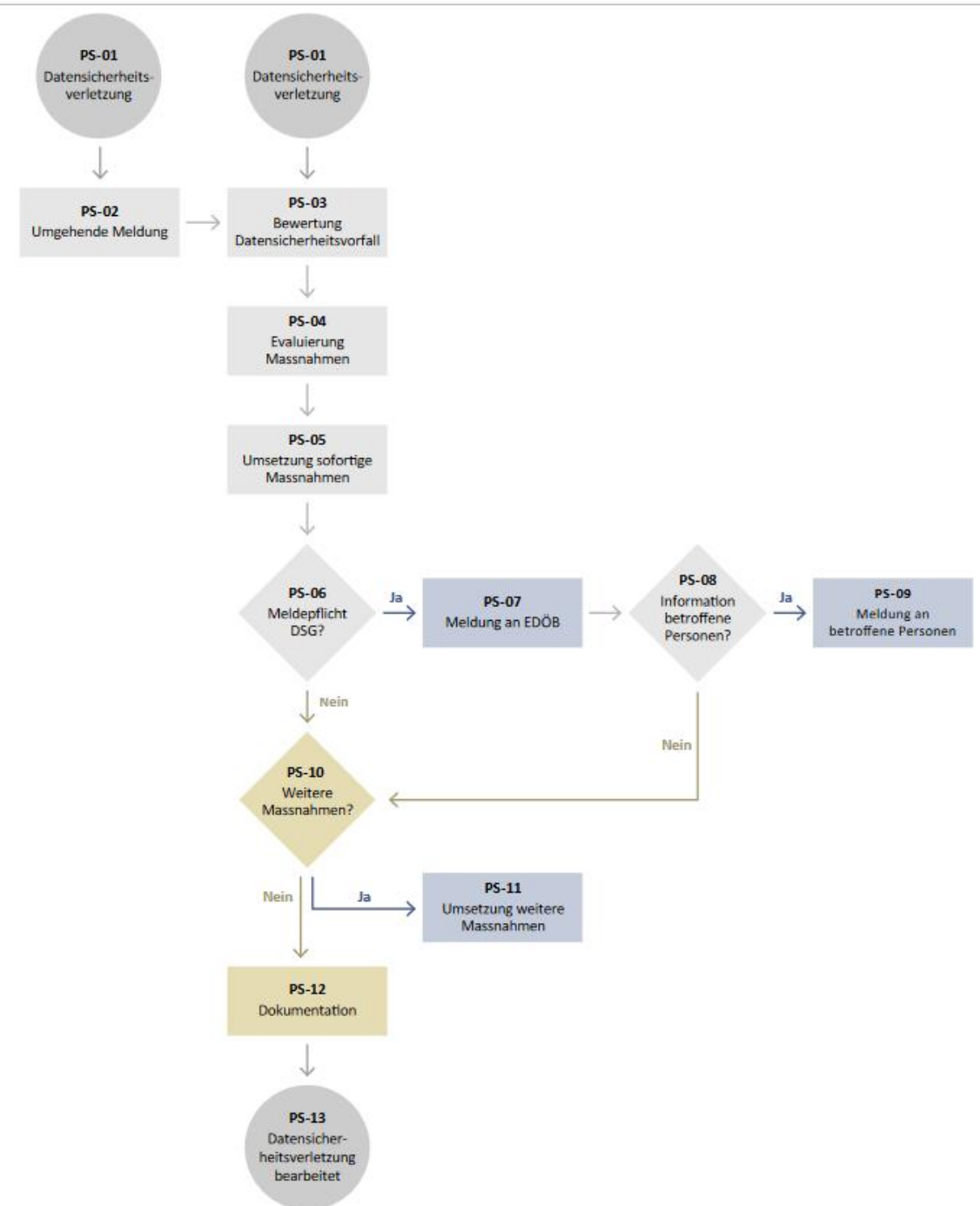
- EDÖB
- Hohes Risiko für die Persönlichkeit
- Grundrechte

Gruppenarbeit: Suchen Sie

- a) Vorfälle von Verletzungen der Datensicherheit in den letzten 24 Monaten
- b) Wo würden Sie von einem grossen Risiko für die Grundrechte oder die Persönlichkeit ausgehen?
- c) Wie sind Sie zu dieser Entscheidung gekommen?

Prozess Meldung Datensicherheits- Verletzung

Prozess nach FMH



Was halten Sie von folgender Kommunikation?

Sehr geehrte Damen und Herren

Wir bedauern, Ihnen mitteilen zu müssen, dass BlitzIT diese Woche Opfer eines Cyberangriffs geworden ist.

Wir müssen Sie informieren, dass Sie aufgrund des Angriffs eine Newsletter-Mitteilung von uns erhalten haben, welcher wahrscheinlich einen infizierten Link mit Schadsoftware enthält. Deshalb:

Öffnen Sie den Link nicht!

Falls Sie den infizierten Link bereits geöffnet haben, **ändern Sie sofort Ihr Passwort.**

Obwohl unser Team schnell reagieren konnte, gehen wir davon aus, dass folgende Daten von Ihnen betroffen sein können:

Ihr Vor- und Nachname

Ihre E-Mail-Adresse

Was halten Sie von folgender Kommunikation?

Unsere IT hat, sobald Sie es feststelle, sofort reagiert. Es war aber nicht mehr zu verhindern, dass die infizierte Mail versandt wurde. Wir untersuchen derzeit mit Hochdruck, wie es zu diesem Vorfall kommen konnte.

Unsere Sicherheitsmassnahmen werden stets den neusten Bedrohungen angepasst, um solche Vorfällen möglichst zu verhindern. Der Schutz Ihrer Daten hat für die den höchsten Stellenwert deshalb werden unsere Sicherheitsmassnahmen regelmässig auf den neusten Stand gebracht und regelmässig überprüft.

Wir entschuldigen uns für allfällig entstandenen Unannehmlichkeiten.

Freundliche Grüsse

BlitzIT

Und was halten Sie von dieser Kommunikation

Sehr geehrte Damen und Herren

Nach dem Hackerangriff auf die Softwarefirma Concevis im November 2023 wurde bekannt, dass auch Daten der ES auf den Systemen von Concevis gespeichert waren. Concevis hatte die Daten zu Testzwecken für die Entwicklung neuer Applikationen erhalten.

Aus umfangreichen Abklärungen in enger Zusammenarbeit mit Concevis geht hervor, dass sich unter den möglicherweise abgeflossenen Daten ältere Listen mit E-Mail- und Postadressen in Zusammenhang mit der Wohneigentumsförderung, den Kapital- und Rentenmeldungen und der internationalen Abgeltungssteuer befinden.

Leider müssen wir Ihnen im Namen der ES mitteilen, dass beim Hackerangriff bedauerlicherweise auch Ihre Post- oder Mailadresse abgeflossen sein könnte. Wir entschuldigen uns dafür.

Hacker könnten die Adresse für Phishingangriffe verwenden oder Adresslisten weiterverkaufen. Bitte achten Sie deshalb in Zukunft noch stärker auf verdächtige E-Mails und melden Sie diese auf der Webseite antiphishing.ch, damit Phishingseiten so rasch als möglich aus dem Internet entfernt werden können.

Diese Information erhalten Sie auch im Rahmen des neuen Datenschutzgesetzes, das am 1. September 2023 in Kraft getreten ist. Es sieht vor, über mögliche Datenabflüsse zu informieren.

Freundliche Grüsse

ES, Kommunikation, 9999 Berg

Und das?

Liebe Kundinnen und Kunden

Wie wir Ihnen bereits mitgeteilt haben, sind wir Opfer eines Cyberangriffs geworden.

Wir haben bisher keine Informationen, welche darauf hinweisen, dass Kundensysteme betroffen sind. Diese sind gut isoliert und nicht exponiert.

Trotzdem ist es wichtig, dass auch der VPN-Zugang von Ihren Systemen zur Helpy geschlossen ist. Zudem empfehlen wir Ihnen, die Passwörter aller AD Logins, die mit der Helpy zu tun haben, zurückzusetzen.

Wir sind daran, zusammen mit externen Spezialisten, das Recovery unserer Systeme zu starten. Aktuell gehen wir davon aus, dass unser Kundenportal «Hi» in den nächsten Tagen nicht zur Verfügung stehen wird. Die Helpy ist weiterhin über den Service Desk und den 7x24 Std. Pikettdienst erreichbar.

Sobald wir weitere Informationen haben, werden wir uns wieder bei Ihnen melden.

Freundliche Grüße

Daniel Muster
CEO

Und 18 Stunden später:

Liebe Kundinnen und Kunden

In der Nacht auf den 7. Februar 2025 ist die Helpy Opfer einer Ransomware Attacke geworden. Um eine Ausbreitung auf weitere Systeme zu verhindern, haben wir alle unsere Systeme heruntergefahren, aus diesem Grund ist unser Betrieb weiterhin stark eingeschränkt.

Wir möchten Ihnen ein detailliertes Statusupdate zum Cyberangriff auf unser Unternehmen geben.

Aktuell analysieren die Cyberspezialisten von Hopp Security unsere Systeme. Die Abteilung Cybercrime der Kantonspolizei Zürich, sowie der Eidgenössische Datenschutz- und Öffentlichkeitsbeauftragter (EDÖB) und das Government Computer Emergency Response Team beim Bundesamt für Cybersicherheit BACS (GovCERT) wurden von uns informiert.

Wie der Angriff stattgefunden hat, ist Gegenstand der aktuellen Analysen. Betroffen sind grundsätzlich alle ans Active Directory angebundenen Dienste. In der Helpy sind folgende Systeme betroffen:

- Exchange Server
- Jira/Confluence
- NAS

Und 18 Stunden später:

Stand jetzt gibt es keine Anhaltspunkte, dass BC und unsere Entwicklungsumgebung kompromittiert wurden. Da die Systeme in der Branche X nicht mit unserem Active Directory verbunden sind, gibt es aktuell keine Indizien, dass die Kundensysteme betroffen sind. Auf den Systemen bei den Kunden sind lokale oder durch den Kunden verwaltete Accounts im Einsatz. Nach derzeitigem Stand sind alle BC-Systeme uneingeschränkt nutzbar und können in Betrieb bleiben. Wir bitten Sie dennoch weiterhin wachsam zu sein, bezüglich Auffälligkeiten oder Unregelmässigkeiten in Ihren Systemen.

Aktuell sind wir daran, unsere Systeme in einer sicheren Umgebung komplett neu aufzubauen. Dies wird einige Zeit in Anspruch nehmen. Über den Service Desk und die Pikettnummer sind wir nach wie vor erreichbar.

Sobald wir neue Erkenntnisse haben, werden wir Sie wieder informieren. Bei Fragen zögern Sie nicht auf uns zuzukommen. Wir danken Ihnen für Ihr Verständnis.

Freundliche Grüsse

Daniel Muster
CEO

24 Stunden später

Liebe Kundinnen und Kunden

Auf das Wochenende hin möchten wir Ihnen ein erneutes Statusupdate zum Cyberangriff auf unser Unternehmen geben.

Nach wie vor sind keine Kundensysteme betroffen und System X läuft bei allen Kunden störungsfrei. Ebenfalls möchten wir betonen, dass wir keine Spezialdaten von Kundensystemen in der Helpy gespeichert haben. Deshalb können wir ausschliessen, dass Spezialdaten verschlüsselt oder gestohlen wurden.

Betroffen sind die an unser Active Directory angebundenen internen Dienste; d.h. der Exchange Server, Jira/Confluence und das NAS. Wir sind aktuell daran, eine neue, sichere IT-Umgebung aufzubauen. Erste Netzwerksegmente sind bereits aufgesetzt. Parallel dazu sind wir daran die Dateien wiederherzustellen und verfügbar zu machen.

Wir sind zuversichtlich, dass wir Anfang nächster Woche den regulären Betrieb schrittweise wieder aufnehmen können. Bis sämtliche Dienste wieder uneingeschränkt zur Verfügung stehen, wird es aber sicher noch einige Zeit dauern.

Bei Fragen zögern Sie bitte nicht, sich telefonisch bei unserem Service Desk zu melden. Über das Wochenende sind wir für Notfälle wie gewohnt über unseren Pikettdienst erreichbar.

Wir alle haben gerade sehr hektische Momente hinter uns. Dank der Unterstützung von externen Spezialistinnen und Spezialisten und dem grossen Einsatz unserer engagierten Mitarbeiterinnen und Mitarbeiter sind wir auf einem guten Weg. Wir möchten uns auch bei Ihnen sehr herzlich für Ihre Geduld und Ihr Verständnis bedanken.

Am Montagnachmittag werden wir Sie wieder mit einem Informationsupdate bedienen.

Freundliche Grüsse
Daniel Muster (CEO)

Gehackt – was nun?

- Meldepflichten nach DSG und ISG:

	DSG	ISG
Was	Art. 24 Abs.1 DSG: Verletzung der Datensicherheit, die voraussichtlich zu einem hohen Risiko für die Persönlichkeit oder die Grundrechte der betroffenen Person führt	Art. 74d ISG: Cyberangriff, wenn dieser: a. die Funktionsfähigkeit der betroffenen kritischen Infrastruktur gefährdet; b. zu einer Manipulation oder zu einem Abfluss von Informationen geführt hat; c. über einen längeren Zeitraum unentdeckt blieb, insbesondere wenn Anzeichen dafür bestehen, dass er zur Vorbereitung weiterer Cyberangriffe ausgeführt wurde; d. mit Erpressung, Drohung oder Nötigung verbunden ist.
Wo	EDÖB	BACS
Frist	So rasch als möglich	Innert 24 Stunden nach Entdeckung des Cyberangriffs
Information Betroffener	Sofern zu deren Schutz notwendig oder auf Verlangen des EDÖB	---
Wer		Nur Organisationen gemäss Art. 74b ISG